



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-45445 AES-OCB IV Ignored on EVP_Cipher() Path

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-15
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-45445 AES-OCB IV Ignored on EVP_Cipher() Path - Vulnerability Report

Published: 2026-06-15 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-45445 is a cryptographic-implementation flaw in OpenSSL's AES-OCB handling when an application uses the low-level one-shot `EVP_Cipher()` interface instead of the documented streaming `EVP_CipherUpdate()` / `EVP_CipherFinal_ex()` path. In the vulnerable code path, the caller-supplied initialization vector (IV) is silently discarded. That causes every message encrypted under a given key to reuse the same effective nonce, undermining OCB's security guarantees.

The defensive significance is twofold. First, nonce reuse under OCB breaks confidentiality, meaning an attacker observing or interacting with a vulnerable implementation can gain leverage far beyond normal ciphertext visibility. Second, if the same flawed path is used when computing the authentication tag, OpenSSL states the tag can become a function only of the `(key, IV)` pair rather than the plaintext or ciphertext, enabling universal forgery of arbitrary ciphertext from a single captured message. This makes the issue more severe than a simple implementation bug: in the right application design, it can collapse both confidentiality and integrity protections.

Exposure is narrower than a general OpenSSL remote code execution event. OpenSSL's own advisory is explicit that the built-in SSL/TLS stack is not affected, AES-OCB is not a TLS cipher suite, FIPS modules are outside scope, and applications using the documented streaming AEAD API are not vulnerable. The at-risk population is therefore custom or embedded applications that both use AES-OCB and drive it through the discouraged `EVP_Cipher()` one-shot API. Defenders should prioritize identifying custom cryptographic implementations, patching OpenSSL to fixed releases, and reviewing any protocol or file-processing workflow that relies on OpenSSL OCB for confidentiality and authenticity.

2. Intelligence Requirement

This report addresses the following intelligence requirement: what does CVE-2026-45445 mean for organizations that ship or depend on OpenSSL-based applications, which environments are actually exposed, and what remediation, detection, and hunting steps should be prioritized now?

Question	Assessment
What is the flaw?	OpenSSL discards the caller-supplied IV when AES-OCB is driven through the public one-shot <code>EVP_Cipher()</code> API path.
What is the primary security impact?	Reuse of the effective nonce under the same key causes loss of confidentiality; if the same path is used for tag generation, the flaw can also enable universal ciphertext forgery.
Which software is directly affected?	OpenSSL 3.0.x before 3.0.21, 3.4.x before 3.4.6, 3.5.x before 3.5.7, 3.6.x before 3.6.3, and 4.0.0 before 4.0.1.
Which software is not directly affected?	OpenSSL 1.1.1 and 1.0.2, OpenSSL's SSL/TLS implementation, OpenSSL FIPS modules, and applications using the documented streaming AEAD interface rather than <code>EVP_Cipher()</code> .
What must be true for exploitation?	A vulnerable application must use AES-OCB and invoke the one-shot <code>EVP_Cipher()</code> path in a way that makes attacker-influenced messages meaningful.
Is broad in-the-wild exploitation confirmed?	No authoritative evidence of KEV inclusion or named public exploitation campaigns was identified during this review.
What fixes the issue?	Upgrade to OpenSSL 3.0.21, 3.4.6, 3.5.7, 3.6.3, 4.0.1, or vendor backports carrying the same fix.
What should defenders do first?	Patch vulnerable OpenSSL branches, inventory custom applications using AES-OCB, and review source code or SBOMs for use of <code>EVP_Cipher()</code> with OCB contexts.

3. Source Review and Confidence

Source	Contribution	Confidence
OpenSSL Security Advisory dated 2026-06-09	Canonical issue summary, impact language, affected branches, unaffected scenarios, and fixed versions	High
OpenSSL vulnerabilities index / version-branch page	Confirms severity labeling, affected release ranges, and remediation versions across maintained branches	High
NVD JSON 2.0 entry	Supplies CVSS 3.1 score, vector, CWE mapping, publication metadata, and upstream reference links	High
Debian Security Tracker	Downstream package remediation detail and fixed package versions across Debian branches	High
Ubuntu security tracker / USN-8414-1	Downstream package status and distro-specific fixed versions for supported Ubuntu releases	High
CISA KEV catalog snapshot	Negative-control check for known exploitation status at review time	High
MSRC Update Guide syndication entry	Confirms visibility in monitored intake feeds but is not the canonical vendor source for OpenSSL mechanics	Medium

Confidence is high on the technical core of CVE-2026-45445 because OpenSSL's own advisory, the version-branch vulnerability pages, NVD, and downstream distro trackers all align on the flaw mechanics and remediation path. The most important analytic caveat is scope: this is not a generic "all OpenSSL users are remotely exploitable" event. The vulnerable condition is limited to applications that selected AES-OCB and used the discouraged one-shot `EVP_Cipher()` path.

Confidence is lower on exploitation prevalence because the reviewed public material did not show CISA KEV inclusion, named victim reporting, or trusted public evidence of active exploitation. The strongest supportable conclusion is that this is a high-impact cryptographic misuse condition with a narrower but potentially severe exposure surface concentrated in bespoke or embedded OpenSSL consumers rather than mainstream TLS usage.

4.1 Vulnerability metadata

Field	Value
CVE	CVE-2026-45445
Product family	OpenSSL
Affected component	AES-OCB provider path when driven through <code>EVP_Cipher()</code>
Vulnerability class	Improper cryptographic IV / nonce handling leading to nonce reuse and forgery risk
Weakness	CWE-325: Missing Required Cryptographic Step
OpenSSL severity	Moderate
NVD severity	CVSS 3.1 7.5 High

NVD vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
Published	2026-06-09
Affected versions	4.0.0 before 4.0.1; 3.6.0 before 3.6.3; 3.5.0 before 3.5.7; 3.4.0 before 3.4.6; 3.0.0 before 3.0.21
Not affected	OpenSSL 1.1.1, OpenSSL 1.0.2, OpenSSL SSL/TLS stack, and OpenSSL FIPS modules
Fixed versions	4.0.1, 3.6.3, 3.5.7, 3.4.6, 3.0.21
Exploitation status	No KEV inclusion or authoritative broad in-the-wild exploitation evidence identified during this review
Discovery / fix credit	Reported by Alex Gaynor (Anthropic); fix developed by Viktor Dukhovni

4.2 Flaw mechanics

OpenSSL's advisory explains that the vulnerable path exists because the OCB provider's streaming handler correctly flushes the application-supplied IV into the OCB context before processing data, but the lower-level one-shot `EVP\_Cipher()` handler did not. As a result, every AES-OCB operation performed through that path ran with the all-zero key-derived offset state left by cipher initialization, regardless of the IV actually supplied by the caller.

That behavior is especially dangerous because OCB relies on nonce uniqueness for its authenticated-encryption guarantees. When each message under the same key uses the same effective nonce, confidentiality collapses. OpenSSL further states that if `EVP\_EncryptFinal\_ex()` is then used to obtain the authentication tag, the deferred IV setup clears the running checksum that should have covered the plaintext. The resulting tag depends only on the `(key, IV)` pair and can verify against arbitrary ciphertext produced under the same `(key, IV)` pair, creating a practical forgery condition.

This is therefore not a simple edge-case bug or a benign parameter-handling failure. It is a cryptographic-state failure that can negate both secrecy and authenticity for applications built on the vulnerable pattern.

4.3 Exposure profile

Exposure pattern	Why it matters	Priority
Custom network protocols using AES-OCB over OpenSSL `EVP_Cipher()`	Network-reachable message handling can turn the flaw into a confidentiality and integrity failure during normal protocol traffic	Immediate
Appliances, embedded products, or in-house services that implemented their own OCB message format	Bespoke crypto wrappers are more likely to use low-level APIs or legacy calling patterns	Immediate
File or object encryption workflows that use AES-OCB one-shot calls	Repeated use under the same key can silently lose nonce uniqueness and invalidate authenticity assumptions	High
Applications using OpenSSL only through libssl / TLS	OpenSSL states TLS is not affected and AES-OCB is not a TLS cipher suite	Reduced

Applications using AES-OCB through `EVP_CipherUpdate()` / `EVP_CipherFinal_ex()`	OpenSSL states the documented streaming API is not affected	Reduced
Estates still on OpenSSL 1.1.1 or 1.0.2	Those branches are not affected by this specific flaw	Reduced

4.4 ATT&CK framing and defensive meaning

ATT&CK mapping is conditional because CVE-2026-45445 is a library flaw, not a confirmed campaign procedure. The following mappings are best treated as exposure-framing aids rather than as proof of observed actor tradecraft.

ATT&CK ID	Technique	Rationale
T1190	Exploit Public-Facing Application	Applicable when a vulnerable custom service exposes an OpenSSL AES-OCB message handler to remote clients.
T1210	Exploitation of Remote Services	Applicable where internal or peer services exchange attacker-influenced OCB-protected traffic via the vulnerable API path.
T1565.001	Data Manipulation: Stored Data Manipulation	Applicable as a defensive framing aid because the flaw can enable forged ciphertext/tag pairs that subvert integrity expectations in custom protocols or stored encrypted objects.

The key defensive implication is that exposure depends far more on application design than on the mere presence of OpenSSL. Teams need to know not only where OpenSSL is installed, but where AES-OCB and the discouraged one-shot API are actually used.

5. Threat Context

CVE-2026-45445 should be treated as a targeted exposure-management problem centered on custom crypto usage. Unlike high-profile OpenSSL issues that broadly affect certificate parsing or TLS negotiation, this flaw does not hit standard libssl traffic. Its operational risk concentrates in products and internal applications that built their own AES-OCB usage model on top of lower-level EVP primitives.

That narrower scope does not make the issue low impact. In environments that do use the vulnerable pattern, the effect is unusually serious because the flaw can undermine both confidentiality and integrity simultaneously. For security teams, the practical challenge is visibility: many organizations have reasonable package inventory for OpenSSL but weak visibility into how embedded libraries are actually exercised inside proprietary applications, appliances, agents, or third-party products.

5.1 Representative abuse scenarios

Scenario	Description	Defensive meaning
Custom protocol endpoint	An internet-facing or partner-facing service uses AES-OCB through `EVP_Cipher()` for application-layer message protection	Patch urgency is highest because attacker-controlled traffic can directly exercise the vulnerable path
Internal service-to-service protocol	A bespoke internal service uses OpenSSL OCB one-shot encryption for authenticated messaging	East-west traffic can still be abused by an attacker with foothold or relay access
Encrypted object or file workflow	A product encrypts files, records, or blobs with AES-OCB using the one-shot API	Stored data assurances can be invalidated if ciphertexts or tags are later trusted as

		authentic
Embedded third-party product	A vendor appliance or software product statically links a vulnerable OpenSSL branch and ships custom OCB logic	OS-level patching may not fully remediate exposure without vendor confirmation

5.2 Exploitation-status assessment

Reviewed public sources did not identify CISA KEV inclusion, named public exploitation campaigns, or widely circulated proof-of-concept exploitation directed at mainstream products. The issue is therefore best assessed as publicly documented, technically serious, but not currently confirmed as broadly weaponized in the open reporting reviewed for this task.

Defenders should nevertheless avoid downgrading the issue solely because exploitation reporting is sparse. Cryptographic misuse flaws often matter most in a smaller set of high-consequence products that built non-standard protocols or data-protection logic. Where OpenSSL OCB one-shot usage exists, the risk is material even without mass exploitation telemetry.

6. Detection and Hunting

Detection for CVE-2026-45445 is primarily an exposure-discovery and secure-code-review problem. There is no stable infrastructure IOC set, malware family, or universal network signature in the reviewed source material. The most valuable detections identify vulnerable OpenSSL versions, confirm whether AES-OCB is in use, and surface code or products invoking `EVP\_Cipher()` in conjunction with OCB contexts.

6.1 Detection coverage summary

Signal	Telemetry source	Analytic goal	Coverage caveat
OpenSSL versions in vulnerable 3.x / 4.0 branches	Software inventory, SBOM, package telemetry, container scans	Identify systems requiring patch validation	Package version alone does not prove vulnerable API usage
Source code or binaries referencing `EVP_Cipher()` and OCB identifiers	SAST, repo scans, symbol strings, code search, SBOM enrichment	Find applications that may exercise the vulnerable path	Statically linked or stripped binaries may hide call patterns
Vendor appliances or products shipping bundled OpenSSL	Vendor advisories, appliance inventory, filesystem inspection	Identify exposure missed by OS package management	Vendor backports can obscure effective remediation status
Integrity failures or unusual crypto-message validation anomalies in custom protocols	App logs, protocol telemetry, custom alerts	Surface possible abuse or implementation breakage	Highly application-specific; rarely visible in generic EDR alone
Build and deployment workflows still pinning vulnerable OpenSSL branches	CI/CD logs, IaC repos, image manifests	Prevent reintroduction of vulnerable versions	Requires development-pipeline telemetry rather than endpoint logs

6.2 Sigma - Linux package inventory review for vulnerable OpenSSL branches

<pre> title: Review Linux Hosts with Potentially Vulnerable OpenSSL 3.x or 4.0 Branches id: 8f4350f5-d3fd-469c-bd0d-33de44e35501 status: experimental description: Identifies package-management activity or inventory telemetry that may expose hosts still running OpenSSL branches affected by CVE-2026-45445. Intended for triage and scoping, not exploit confirmation. author: Lost Boys Cyber date: 2026-06-15 references: - https://openssl-library.org/news/secadv/20260609.txt - https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-45445 logsource: </pre>
--

```

product: linux
category: process_creation
detection:
  selection_cmd:
    CommandLine|contains:
      - 'openssl version'
      - 'dpkg -l openssl'
      - 'rpm -qa openssl'
      - 'apt list --installed openssl'
      - 'apk info openssl'
  selection_versions:
    CommandLine|contains:
      - '3.0.'
      - '3.4.'
      - '3.5.'
      - '3.6.'
      - '4.0.0'
  condition: selection_cmd and selection_versions
falsepositives:
  - Routine asset inventory and compliance collection
level: low
tags:
  - attack.t1190
  - attack.t1210

```

6.3 KQL - inventory systems with OpenSSL packages requiring review

```

DeviceTvmSoftwareInventory
| where SoftwareName has_any ("openssl", "libssl", "libcrypto")
| project DeviceName, SoftwareName, SoftwareVersion, Vendor
| order by DeviceName asc, SoftwareName asc

```

6.4 KQL - identify likely code-review targets using OCB or low-level EVP APIs

```

DeviceFileEvents
| where Timestamp > ago(30d)
| where FileName endswith ".c" or FileName endswith ".cc" or FileName endswith ".cpp" or FileName endswith ".h"
| where InitiatingProcessCommandLine has_any ("git", "grep", "rg", "clang", "gcc", "cmake", "make")
| where FolderPath has_any ("src", "include", "crypto", "openssl")
| project Timestamp, DeviceName, FileName, FolderPath, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc

```

6.5 SPL - package and binary exposure triage for OpenSSL 3.x / 4.0

```

(index=os OR index=edr OR index=packages)
("openssl" OR "libssl" OR "libcrypto")
("3.0." OR "3.4." OR "3.5." OR "3.6." OR "4.0.0")
| stats values(host) values(package_name) values(package_version) values(file_path) by sourcetype
| sort host

```

6.6 Hunt questions

Hypothesis	What to prove or disprove
Some enterprise products still ship vulnerable OpenSSL branches even though the base OS package is fixed	Review bundled libraries inside appliances, containers, agent directories, and vendor software trees
At least one in-house service uses AES-OCB through low-level EVP primitives	Search source repositories, static analysis findings, and SBOM notes for `EVP_Cipher` plus OCB identifiers
Development pipelines can still build images with affected OpenSSL versions	Inspect Dockerfiles, lockfiles, CI artifacts, and internal package mirrors for pinned vulnerable branches

A custom protocol or object-encryption workflow could be exposed to attacker-controlled messages	Review application trust boundaries, partner integrations, and data flows where encrypted content is accepted from external actors
--	--

No stable IOC set was identified in reviewed public reporting. Hunting should center on exposure confirmation, code-path validation, and vendor-package assurance rather than classic IP/domain/hash blocking.

7. Recommendations

Priority	Owner	Recommendation	Rationale
Critical	Platform engineering / package owners	Upgrade OpenSSL to 3.0.21, 3.4.6, 3.5.7, 3.6.3, 4.0.1, or vendor-confirmed backports	Removes the vulnerable AES-OCB one-shot behavior in affected branches
Critical	Application owners / developers	Identify code using AES-OCB with <code>EVP_Cipher()</code> and migrate to the documented streaming <code>EVP_CipherUpdate()</code> / <code>EVP_CipherFinal_ex()</code> flow	OpenSSL explicitly states the streaming API is not affected
High	Product security	Inventory third-party products, appliances, containers, and agents that bundle OpenSSL rather than relying on OS packages	Embedded copies may remain vulnerable after normal package patching
High	Detection engineering	Add exposure analytics for vulnerable OpenSSL branches and code-review targeting for <code>EVP_Cipher()</code> plus OCB usage	The key problem is narrow but high-consequence API usage, not generic OpenSSL presence usage
High	Security architecture	Review any custom protocol or object-protection design that relies on OpenSSL AES-OCB for external or semi-trusted traffic	These are the environments where confidentiality and integrity guarantees may collapse
Medium	Incident response	Preserve suspicious encrypted messages, protocol captures, and application logs if a vulnerable custom service shows unexplained authentication anomalies	Evidence may be required to determine whether abuse or integrity bypass occurred
Medium	Vendor management	Request explicit remediation statements from vendors whose products ship custom OpenSSL-based encryption logic	Version disclosure and backport status may be unclear without direct vendor confirmation

Immediate priorities are to patch affected branches, locate AES-OCB one-shot usage in custom code, and validate whether any business-critical products trust OpenSSL OCB-protected messages from outside their trust boundary. If no such usage exists, practical risk may be substantially lower than the headline CVSS suggests. If such usage does exist, remediation urgency should be treated as high despite the narrower exposure population.

8. References

- 1. OpenSSL Security Advisory, 9 June 2026
- <https://openssl-library.org/news/secadv/20260609.txt>
- 2. OpenSSL vulnerabilities index
- <https://openssl-library.org/news/vulnerabilities/>
- 3. OpenSSL vulnerabilities 3.4 branch page
- <https://openssl-library.org/news/vulnerabilities-3.4/>
- 4. NVD JSON 2.0 entry for CVE-2026-45445
- <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-45445>
- 5. NVD detail page for CVE-2026-45445
- <https://nvd.nist.gov/vuln/detail/CVE-2026-45445>
- 6. Debian Security Tracker entry for CVE-2026-45445
- <https://security-tracker.debian.org/tracker/CVE-2026-45445>
- 7. Ubuntu security tracker entry for CVE-2026-45445
- <https://ubuntu.com/security/CVE-2026-45445>
- 8. Ubuntu Security Notice USN-8414-1
- <https://ubuntu.com/security/notices/USN-8414-1>
- 9. CISA Known Exploited Vulnerabilities catalog
- https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- 10. Microsoft Security Update Guide syndication entry
- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-45445>